



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-42903 Windows Kerberos Denial of Service Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-42903 Windows Kerberos Denial of Service Vulnerability - Vulnerability Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-42903 is an Important Windows Kerberos denial-of-service vulnerability published by Microsoft on 2026-06-09 and re-touched in the Security Update Guide on 2026-06-10 as an informational acknowledgement update. Microsoft, the CVE Program CNA record, NVD, and CISA vulnrichment data align that the bug is a null pointer dereference (`CWE-476`) in Windows Kerberos. A successful attack allows an authorized attacker to deny service over a network; the public record does not indicate confidentiality or integrity impact, but it does indicate high availability impact.

For most organizations, the highest operational risk is not generic workstation disruption but interruption of Kerberos-backed authentication workflows on high-value Windows infrastructure. Kerberos underpins authentication across Active Directory environments, so service instability on domain controllers or other central authentication systems can degrade logons, service tickets, and broader business operations. The public advisory language does not describe a wormable or unauthenticated remote condition, but it does confirm that exploitation is network-reachable and only requires low privileges.

At review time, the strongest public evidence indicates broad product exposure and limited exploitation evidence. Microsoft rates the issue Important with CVSS v3.1 base score 6.5, marks the latest-software-release exploitability assessment as “Exploitation Unlikely,” and states the issue was not publicly disclosed or exploited at publication. CISA’s 2026-06-10 vulnrichment record sets SSVSC `Exploitation: none`, `Automatable: no`, and `Technical Impact: partial`. Defensive priority should therefore center on patch verification, Kerberos-service resilience monitoring, and focused hunting for pre-remediation service interruptions or suspicious authentication-failure clusters.

Executive takeaway	Assessment
Business impact	Authentication outages and service disruption are the primary risk, especially where Kerberos is critical to identity and access workflows.
Attacker requirement	Low-privilege authorized attacker with network reach to the affected Kerberos service.
Public exploitation status	No reviewed authoritative source confirmed in-the-wild exploitation as of 2026-06-10.
Immediate priority	Patch affected Windows clients and servers, verify fixed build adoption, and monitor for Kerberos-related instability on unpatched or recently patched systems.

2. Intelligence Requirement

This review addresses the following intelligence requirement: what does the current public record say about `CVE-2026-42903`, which Windows platforms are exposed, how likely is opportunistic exploitation, and what should defenders do immediately to reduce authentication-service disruption risk?

Question	Assessment
What is the vulnerability?	A null pointer dereference in Windows Kerberos that can let an authorized attacker cause denial of service over a network.
What access does the attacker need?	Low privileges (`PR:L`) and network access (`AV:N`) to the vulnerable Kerberos service path.
What is the primary impact?	Availability impact only in the reviewed public record (`C:N/I:N/A:H`).
Is the issue broadly exposed?	Yes. Microsoft lists affected Windows 10, Windows 11, and Windows Server branches, including Server Core variants where

	applicable.
Is public exploitation confirmed?	No. Microsoft marks the issue as not publicly disclosed and not exploited at publication; CISA vulnrichment also records `Exploitation: none`.
What matters most to defenders?	Validate patch coverage, prioritize identity-critical Windows systems, and investigate Kerberos instability or abnormal authentication-failure spikes on systems that remained unpatched after the June 2026 release.

3. Source Review and Confidence

Source	Contribution	Confidence
Microsoft Security Update Guide entry	Canonical CVE title, advisory language, and current public status page.	High
Microsoft June 2026 CVRF document	Product-by-product remediation KBs, affected-product mapping, exploitability assessment, and Microsoft threat labels.	High
CVE Program CNA record	Publication timing, affected version ranges, weakness mapping, and CVSS vector.	High
NVD JSON 2.0 record	Corroborates CNA description, CVSS semantics, and analysis state in a normalized public feed.	High
CISA vulnrichment record	Adds SSVC context: exploitation none, automatable no, technical impact partial.	High
Rapid7 June 2026 Patch Tuesday review	Independent defender-oriented corroboration that Microsoft assessed exploitation as unlikely.	Medium
Zero Day Initiative June 2026 update review	Independent corroboration that the issue was tracked publicly as an Important Windows Kerberos DoS with no public exploitation/disclosure flags in that review.	Medium

Confidence is high on the existence of the vulnerability, the affected product families, the CVSS semantics, and the remediation path because those facts are directly supported by Microsoft, the CNA record, NVD, and CISA enrichment. Confidence is lower on precise exploit mechanics, crash manifestations, and exploit-detection opportunities because the reviewed public sources do not provide proof-of-concept material, packet-level exploit detail, or stable exploit-specific telemetry. Detection and hunting guidance in this report is therefore intentionally defensive and behavior-oriented rather than framed as a deterministic exploit signature.

A reporting nuance worth preserving is that the intake event on 2026-06-10 was triggered by an acknowledgement update in the Security Update Guide, not by new evidence of active exploitation. That reduces the likelihood that the source item itself represented a material threat-status change, but it does not reduce the operational relevance of the underlying vulnerability across supported Windows environments.

4.1 Core Vulnerability Metadata

Field	Value
CVE	`CVE-2026-42903`

Vulnerability name	`Windows Kerberos Denial of Service Vulnerability`
Weakness	`CWE-476` NULL Pointer Dereference
Severity	`6.5 / MEDIUM` (Microsoft CVSS v3.1)
CVSS v3.1 vector	`AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`
Attack vector	Network
Privileges required	Low
User interaction	None
Scope	Unchanged
Impact profile	Availability only (`A:H`) in reviewed public records
Microsoft severity label	Important
Public disclosure at release	No
Exploitation at release	No
Microsoft exploitability assessment	Exploitation Unlikely
CISA SSVC summary	`Exploitation: none`, `Automatable: no`, `Technical Impact: partial`
First public release	2026-06-09
Intake update reviewed	2026-06-10 acknowledgement change

4.2 Affected Platform and Patch Matrix

Platform family	Vulnerable before	Microsoft remediation
Windows 10 1607 / Windows Server 2016	`10.0.14393.9234`	`KB5094122`
Windows 10 1809 / Windows Server 2019	`10.0.17763.8880`	`KB5094123`
Windows 10 21H2 / 22H2	`10.0.19044.7417` / `10.0.19045.7417`	`KB5094127`
Windows 11 23H2	`10.0.22631.7219`	`KB5093998`
Windows 11 24H2 / 25H2	`10.0.26100.8655` / `10.0.26200.8655`	`KB5094126`
Windows 11 26H1	`10.0.28000.2269`	`KB5095051`
Windows Server 2012	`6.2.9200.26132`	`KB5094042`
Windows Server 2012 R2	`6.3.9600.23228`	`KB5094041`
Windows Server 2022	`10.0.20348.5256`	`KB5094128`
Windows Server 2025	`10.0.26100.32995`	`KB5094125`

Microsoft's CVRF record also lists Server Core variants for multiple affected server releases. Those systems should be treated as fully in scope, even where their attack surface is operationally smaller than GUI-based deployments.

4.3 Analyst Findings

Finding	Defensive implication
The issue is network-reachable but not unauthenticated; the attacker must already be an authorized low-privilege principal.	Prioritize systems where semi-trusted users, service accounts, or compromised internal identities could reach Kerberos services.
The public impact record is confined to availability, but in identity-centric environments availability loss can become a business-critical event.	Treat domain controllers and identity infrastructure as higher-priority remediation targets than ordinary endpoints.
No reviewed authoritative source tied the CVE to public exploitation, KEV inclusion, or a named campaign as of 2026-06-10.	Avoid overstating live exploitation while still reducing exposure promptly due to the breadth of affected Windows versions.
The trigger for this intake item was an acknowledgement update, not a newly disclosed exploit development.	Use this as a reminder to validate whether feed updates reflect status changes or editorial changes before reprioritizing.
No public IOC set, exploit sample, or exploit-specific crash signature was identified in the reviewed source set.	Detection should focus on exposure management, Kerberos failure spikes, and service-instability triage instead of signature-only logic.

5. Threat Context

CVE-2026-42903 is best modeled as an internal service-disruption opportunity rather than an initial-access vulnerability. The low-privilege requirement means the attacker already needs some form of authenticated position: for example, a compromised domain user account, a foothold on an internal Windows host, a malicious insider, or an abused service account. That requirement lowers opportunistic internet-scale abuse potential relative to unauthenticated Kerberos flaws, but it still leaves meaningful room for targeted disruption inside enterprise networks.

The environments with the highest practical risk are those where Kerberos service continuity is mission-critical: Active Directory domain controllers, application servers dependent on ticket-based authentication, jump hosts, and shared Windows infrastructure serving large user populations. In those settings, even a vulnerability that only affects availability can have cascading operational consequences, including failed logons, service-ticket disruption, delayed administrative workflows, and temporary interruption of downstream services that depend on Kerberos trust.

No reviewed source established a named threat actor, malware family, or active exploitation campaign for this CVE. Rapid7's June 2026 Patch Tuesday review described the issue as "Exploitation Unlikely," and Zero Day Initiative's June 2026 update review likewise listed no public exploitation or disclosure flags for this entry. CISA's reviewed KEV feed snapshot dated 2026-06-09 did not include `CVE-2026-42903`. That absence should be treated as time-bounded negative evidence, not as proof that weaponization will never emerge.

MITRE ATT&CK mapping	Relevance	Confidence
`T1499` Endpoint Denial of Service	Best-fit public ATT&CK mapping because the described outcome is denial of service against a Windows authentication component.	Medium
Additional ATT&CK techniques	Not assigned with high confidence from the reviewed public record. Follow-on behaviors after disruption are environment-dependent and not evidenced in source reporting.	High

6. Detection and Hunting

Because public reporting does not currently expose exploit packets, proof-of-concept tooling, or a stable exploit fingerprint, the most defensible monitoring approach is layered: identify vulnerable systems, detect service instability in Kerberos-relevant roles, and hunt for authentication-failure anomalies or suspicious activity clustered around those disruptions.

6.1 Detection Logic Summary

Signal	Telemetry source	Analytic goal
Hosts below the Microsoft fixed build numbers	Asset inventory, EDR device inventory, WSUS/SCCM/Intune/Update telemetry	Identify exposure and prioritize remediation
Spikes in Kerberos authentication failures from a single source account or host	Domain controller Security logs, SIEM authentication telemetry	Surface possible exploit attempts, protocol misuse, or noisy testing activity
Application faults, service crashes, or reboots affecting Kerberos-relevant Windows infrastructure	Windows System/Application logs, WER, EDR device events	Detect service disruption that may reflect exploit attempts or successful denial conditions
Sudden concentration of service-ticket failures on domain controllers after a suspicious source host becomes active	Security logs, SIEM correlation, network telemetry	Link actor activity to downstream authentication disruption
Persistent failures on unpatched systems after June 2026 patch deployment windows	Vulnerability management and incident tracking	Distinguish normal patch lag from hosts potentially being exercised or stressed by attacker activity

Analyst caveat: none of the reviewed public sources claim that exploitation always produces a crash artifact with a stable event ID, process name, or module string. Queries below should be treated as pragmatic triage pivots rather than exploit-confirmation logic.

6.2 Example Sigma Logic

<pre> title: Possible Kerberos Service Disruption on Windows Infrastructure id: e12f9fe1-4290-4303-8d8d-kerberos-dos status: experimental description: Hunts for Windows service-failure or application-error events that may merit review during CVE-2026-42903 investigations on Kerberos-relevant systems. logsource: product: windows service: system detection: selection_service_failure: EventID: - 7031 - 7034 selection_app_error: EventID: - 1000 - 1001 condition: selection_service_failure or selection_app_error falsepositives: - routine service restarts during patching or maintenance - unrelated application crashes on non-Kerberos systems level: medium </pre>

6.3 Example Hunt Queries

Exposure inventory by build:

<pre> DeviceInfo summarize arg_max(Timestamp, *) by DeviceId </pre>

```
| project DeviceName, OSPlatform, OSVersion, OSBuild, Timestamp
| order by OSBuild asc
```

Domain-controller authentication-failure clustering (Microsoft Sentinel / SecurityEvent schema assumption):

```
SecurityEvent
| where TimeGenerated > ago(14d)
| where EventID in (4768, 4769, 4771)
| summarize FailureCount=count() by bin(TimeGenerated, 15m), Computer, IPAddress, TargetUserName,
EventID
| where FailureCount > 25
| order by TimeGenerated desc
```

Windows service/application instability triage:

```
Event
| where TimeGenerated > ago(14d)
| where EventLog in ("System", "Application")
| where EventID in (7031, 7034, 1000, 1001)
| project TimeGenerated, Computer, EventLog, EventID, Source, RenderedDescription
| order by TimeGenerated desc
```

Splunk correlation for Kerberos-related failure spikes:

```
index=wineventlog (EventCode=4768 OR EventCode=4769 OR EventCode=4771)
| bucket span=15m _time
| stats count by _time, host, src_ip, user, EventCode
| where count > 25
| sort - _time
```

6.4 Hunting Guidance

Hunt question	Why it matters
Which domain controllers or identity-relevant Windows servers remained below the fixed builds after 2026-06-09?	These assets are the best starting set for focused retrospective review.
Do unpatched systems show concentrated Kerberos failures from one account or source IP shortly before service instability?	That pattern would be consistent with exploit testing or authentication-path abuse.
Did service interruption correlate with insider activity, newly compromised hosts, or unusual lateral-movement preparation?	The privilege requirement makes already-authenticated internal actors the most relevant threat model.
Were there transient authentication outages around patch windows that were dismissed as operational noise?	Some disruptive activity may be mis-triaged as routine platform instability.
Are exceptions concentrated on jump hosts, shared servers, or administrative enclaves?	Those environments increase the value of even availability-only impact on authentication infrastructure.

7. Recommendations

Priority	Owner	Action
Critical	Windows Platform / Infrastructure	Deploy the June 2026 Microsoft updates for all affected Windows branches, including Server Core variants where listed in Microsoft's CVRF mapping.
Critical	Identity / Active Directory	Prioritize domain controllers and other Kerberos-dependent infrastructure for patch verification before lower-impact endpoint populations.
High	Vulnerability Management	Verify remediation by KB or fixed build number, not by generic “patched” state

		alone.
High	SOC / Detection Engineering	Add temporary dashboards and hunts for Kerberos failure spikes, service-instability events, and unpatched identity systems.
High	Incident Response	Review any authentication outages or Kerberos-related service failures on unpatched systems since 2026-06-09 for signs of malicious triggering rather than assuming routine instability.
Medium	IAM / Server Owners	Reduce unnecessary service-account exposure and review which semi-trusted user populations can reach high-value Kerberos infrastructure.
Medium	Threat Intelligence	Recheck KEV, Microsoft advisories, and public exploit reporting across subsequent patch cycles in case exploitation status changes.

Additional analyst guidance:

- Treat the absence of public exploitation evidence as a reason to calibrate messaging, not as a reason to defer patching on identity-critical systems.
- If patching must be delayed, document the exception, increase log retention for domain-controller authentication telemetry, and put temporary alerting around repeated Kerberos failures and service-disruption events.
- Where telemetry maturity is limited, exposure reduction through patching and infrastructure prioritization is more reliable than attempting to build a high-confidence exploit signature from sparse public data.

8. References

- 1. Microsoft Security Update Guide: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-42903>
- 2. Microsoft Security Response Center CVRF, June 2026 Security Updates: <https://api.msrc.microsoft.com/cvrf/v3.0/cvrf/2026-Jun>
- 3. CVE Program CNA API record: <https://cveawg.mitre.org/api/cve/CVE-2026-42903>
- 4. CISA vulnrichment record: <https://raw.githubusercontent.com/cisagov/vulnrichment/develop/2026/42xxx/CVE-2026-42903.json>
- 5. NVD JSON 2.0 API query: <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-42903>
- 6. Rapid7, Patch Tuesday - June 2026: <https://www.rapid7.com/blog/post/em-patch-tuesday-june-2026/>
- 7. Zero Day Initiative, The June 2026 Security Update Review: <https://www.zerodayinitiative.com/blog/2026/6/9/the-june-2026-security-update-review>
- 8. CISA Known Exploited Vulnerabilities JSON feed: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json